



ZAP Scanning Report

Site: <http://localhost:8000>

Generated on Thu, 6 Aug 2026 09:13:54

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	0
Low	2
Informational	5
False Positives:	0

Insights

Level	Reason	Site	Description	Statistic
Info	Informational	http://localhost:8000	Percentage of responses with status code 2xx	50 %
Info	Informational	http://localhost:8000	Percentage of responses with status code 4xx	50 %
Info	Informational	http://localhost:8000	Percentage of endpoints with content type application/json	100 %
Info	Informational	http://localhost:8000	Percentage of endpoints with method GET	100 %
Info	Informational	http://localhost:8000	Count of total endpoints	2

Summary of Sequences

For each step: result (Pass/Fail) - risk (of highest alert(s) for the step, if any).

Alerts

Name	Risk Level	Number of Instances
Cross-Origin-Resource-Policy Header Missing or Invalid	Low	1
X-Content-Type-Options Header Missing	Low	1
Sec-Fetch-Dest Header is Missing	Informational	3
Sec-Fetch-Mode Header is Missing	Informational	3

Sec-Fetch-Site Header is Missing	Informational	3
Sec-Fetch-User Header is Missing	Informational	3
Storable and Cacheable Content	Informational	3

Alert Detail

Low	Cross-Origin-Resource-Policy Header Missing or Invalid
Description	Cross-Origin-Resource-Policy header is an opt-in header designed to counter side-channels attacks like Spectre. Resource should be specifically set as shareable amongst different origins.
URL	http://localhost:8000
Node Name	http://localhost:8000
Method	GET
Parameter	Cross-Origin-Resource-Policy
Attack	
Evidence	
Other Info	
Instances	1
Solution	Ensure that the application/web server sets the Cross-Origin-Resource-Policy header appropriately, and that it sets the Cross-Origin-Resource-Policy header to 'same-origin' for all web pages. 'same-site' is considered as less secured and should be avoided. If resources must be shared, set the header to 'cross-origin'. If possible, ensure that the end user uses a standards-compliant and modern web browser that supports the Cross-Origin-Resource-Policy header (https://caniuse.com/mdn-http_headers_cross-origin-resource-policy).
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross-Origin-Embedder-Policy
CWE Id	693
WASC Id	14
Plugin Id	90004

Low	X-Content-Type-Options Header Missing
Description	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
URL	http://localhost:8000
Node Name	http://localhost:8000
Method	GET
Parameter	x-content-type-options
Attack	

Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
Instances	1
Solution	Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application/web server to not perform MIME-sniffing.
Reference	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) https://owasp.org/www-community/Security-Headers
CWE Id	693
WASC Id	15
Plugin Id	10021

Informational	Sec-Fetch-Dest Header is Missing
Description	Specifies how and where the data would be used. For instance, if the value is audio, then the requested resource must be audio data and not any other type of resource.
URL	http://localhost:8000
Node Name	http://localhost:8000
Method	GET
Parameter	Sec-Fetch-Dest
Attack	
Evidence	
Other Info	
URL	http://localhost:8000/robots.txt
Node Name	http://localhost:8000/robots.txt
Method	GET
Parameter	Sec-Fetch-Dest
Attack	
Evidence	
Other Info	
URL	http://localhost:8000/sitemap.xml
Node Name	http://localhost:8000/sitemap.xml
Method	GET
Parameter	Sec-Fetch-Dest
Attack	
Evidence	

Other Info	
Instances	3
Solution	Ensure that Sec-Fetch-Dest header is included in request headers.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Sec-Fetch-Dest
CWE Id	352
WASC Id	9
Plugin Id	90005

Informational	Sec-Fetch-Mode Header is Missing
Description	Allows to differentiate between requests for navigating between HTML pages and requests for loading resources like images, audio etc.
URL	http://localhost:8000
Node Name	http://localhost:8000
Method	GET
Parameter	Sec-Fetch-Mode
Attack	
Evidence	
Other Info	
URL	http://localhost:8000/robots.txt
Node Name	http://localhost:8000/robots.txt
Method	GET
Parameter	Sec-Fetch-Mode
Attack	
Evidence	
Other Info	
URL	http://localhost:8000/sitemap.xml
Node Name	http://localhost:8000/sitemap.xml
Method	GET
Parameter	Sec-Fetch-Mode
Attack	
Evidence	
Other Info	
Instances	3
Solution	Ensure that Sec-Fetch-Mode header is included in request headers.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Sec-Fetch-Mode
CWE Id	352
WASC Id	9
Plugin Id	90005

Informational	Sec-Fetch-Site Header is Missing
Description	Specifies the relationship between request initiator's origin and target's origin.
URL	http://localhost:8000
Node Name	http://localhost:8000
Method	GET
Parameter	Sec-Fetch-Site
Attack	
Evidence	
Other Info	
URL	http://localhost:8000/robots.txt
Node Name	http://localhost:8000/robots.txt
Method	GET
Parameter	Sec-Fetch-Site
Attack	
Evidence	
Other Info	
URL	http://localhost:8000/sitemap.xml
Node Name	http://localhost:8000/sitemap.xml
Method	GET
Parameter	Sec-Fetch-Site
Attack	
Evidence	
Other Info	
Instances	3
Solution	Ensure that Sec-Fetch-Site header is included in request headers.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Sec-Fetch-Site
CWE Id	352
WASC Id	9
Plugin Id	90005

Informational	Sec-Fetch-User Header is Missing
Description	Specifies if a navigation request was initiated by a user.
URL	http://localhost:8000
Node Name	http://localhost:8000
Method	GET
Parameter	Sec-Fetch-User
Attack	

Evidence	
Other Info	
URL	http://localhost:8000/robots.txt
Node Name	http://localhost:8000/robots.txt
Method	GET
Parameter	Sec-Fetch-User
Attack	
Evidence	
Other Info	
URL	http://localhost:8000/sitemap.xml
Node Name	http://localhost:8000/sitemap.xml
Method	GET
Parameter	Sec-Fetch-User
Attack	
Evidence	
Other Info	
Instances	3
Solution	Ensure that Sec-Fetch-User header is included in user initiated requests.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Sec-Fetch-User
CWE Id	352
WASC Id	9
Plugin Id	90005

Informational	Storable and Cacheable Content
Description	The response contents are storable by caching components such as proxy servers, and may be retrieved directly from the cache, rather than from the origin server by the caching servers, in response to similar requests from other users. If the response data is sensitive, personal or user-specific, this may result in sensitive information being leaked. In some cases, this may even result in a user gaining complete control of the session of another user, depending on the configuration of the caching components in use in their environment. This is primarily an issue where "shared" caching servers such as "proxy" caches are configured on the local network. This configuration is typically found in corporate or educational environments, for instance.
URL	http://localhost:8000
Node Name	http://localhost:8000
Method	GET
Parameter	
Attack	
Evidence	
Other Info	In the absence of an explicitly specified caching lifetime directive in the response, a liberal lifetime heuristic of 1 year was assumed. This is permitted by rfc7234.
URL	http://localhost:8000/robots.txt

Node Name	http://localhost:8000/robots.txt
Method	GET
Parameter	
Attack	
Evidence	
Other Info	In the absence of an explicitly specified caching lifetime directive in the response, a liberal lifetime heuristic of 1 year was assumed. This is permitted by rfc7234.
URL	http://localhost:8000/sitemap.xml
Node Name	http://localhost:8000/sitemap.xml
Method	GET
Parameter	
Attack	
Evidence	
Other Info	In the absence of an explicitly specified caching lifetime directive in the response, a liberal lifetime heuristic of 1 year was assumed. This is permitted by rfc7234.
Instances	3
Solution	Validate that the response does not contain sensitive, personal or user-specific information. If it does, consider the use of the following HTTP response headers, to limit, or prevent the content being stored and retrieved from the cache by another user: Cache-Control: no-cache, no-store, must-revalidate, private Pragma: no-cache Expires: 0 This configuration directs both HTTP 1.0 and HTTP 1.1 compliant caching servers to not store the response, and to not retrieve the response (without validation) from the cache, in response to a similar request.
Reference	https://datatracker.ietf.org/doc/html/rfc7234 https://datatracker.ietf.org/doc/html/rfc7231 https://www.w3.org/Protocols/rfc2616/rfc2616-sec13.html
CWE Id	524
WASC Id	13
Plugin Id	10049

Sequence Details

With the associated active scan results.